



State of Ohio IT Standard

No:
ITS-SEC-02

Enterprise Security Controls Framework

Effective:
April 29, 2025

Approved By:
Katrina Flory, Assistant Director/State CIO

I. Purpose

This state IT standard specifies the minimum requirements for information security in all agencies and identifies the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53 (Revision 4), "Security and Privacy Controls for Federal Information Systems and Organizations," as the framework for information security controls implementation for the state. The first occurrence of a defined term in the policy body outside of a title or heading is in bold, italic type, and is hyperlinked to the definition in Section IV.

II. Scope

This policy applies to all state Agencies, boards, and commissions under the authority of the Governor (collectively referred to as Agency or Agencies) and to employees, contractors, temporary personnel and other agents of those Agencies (collectively referred to as Individuals).

III. Standard

State agencies shall use NIST SP 800-53 (Revision 4), as the basis for selecting information security controls. The selection and implementation of individual controls shall be based upon **System Classification** and an overall understanding of the risks posed to that system.

To establish an information security baseline across all state agencies and address the currently known, high-priority attacks, agencies are required to implement the enterprise controls listed below.

- A. **Enterprise Controls:** Agencies shall work with the Ohio Department of Administrative Services (DAS) Office of Information Technology (OIT) to implement enterprise security

controls and shall leverage enterprise IT security services unless granted an exception by the DAS Office of Information Security and Privacy (OISP) (refer to section III.B.1.).

1. **Inventory and Control of Hardware Assets:** Agencies shall maintain an up-to-date inventory of authorized devices that are permitted to connect to the agency's network and shall develop processes to detect and prevent unauthorized devices from gaining access, consistent with the guidance in the CIS Controls.
2. **Inventory and Control of Software Assets:** Agencies shall maintain an up-to-date inventory of authorized software and shall develop processes to detect and prevent the installation of unauthorized software, consistent with guidance in the CIS Controls.
3. **Continuous Vulnerability Management:** Agencies shall develop policies and procedures that are consistent with the guidance in the CIS Controls and in the risk assessment (RA) family of controls in NIST SP 800-53 (Revision 4). Agencies shall utilize the enterprise vulnerability assessment services offered by DAS OISP. DAS and agencies shall share responsibility for the remediation of vulnerabilities on ***DAS-Managed Information Systems*** as outlined in service level agreements.
4. **Controlled Use of Administrative Privileges:** Agencies shall implement controls for the assignment, use, and configuration of administrative privileges consistent with the guidance in the CIS Controls.
5. **Secure Configuration for Hardware and Software on Mobile Devices, Laptops, Workstations, and Servers:** Agencies shall adopt and actively maintain common hardware and software configurations on mobile devices, laptops, workstations, and servers, with documented security configurations, consistent with the guidance in the CIS Controls.

DAS OISP provides all state agencies with access to the CIS Benchmarks, which offer secure baseline configurations for common laptop, workstation, and server operating systems (refer to section III.B.2.).

6. **Maintenance, Monitoring, and Analysis of Audit Logs:** Agencies shall implement auditing and logging capabilities and procedures to help detect, understand, or recover from an attack. Agencies shall forward system and/or audit logs to the enterprise security information and event management (SIEM) solution.
7. **E-mail and Web Browser Protections.** Agencies shall first employ DAS OIT provided e-mail and web browser controls. Agencies shall consult with DAS OIT to implement supplemental controls within their environment based on their risk profile. Agencies shall use supported e-mail clients and web browsers.
8. **Malware Defenses:** Agencies shall utilize the enterprise anti-malware services that are offered by DAS OISP, which are configured according to the guidance in the CIS Controls.

9. **Limitation and Control of Network Ports, Protocols, and Services:** Agencies shall identify and enable only necessary network ports, protocols and services based on validated business needs. Agencies shall periodically review existing ports and services to ensure that the need remains. Where DAS manages systems for an agency, the agency shall work with DAS OIT to implement this control.
10. **Data Recovery Capabilities:** Agencies shall develop data backup and recovery plans based on the business needs of the system, and work with DAS OIT to implement and validate these plans on DAS-Managed Information Systems. These data backup and recovery plans shall include regular, automated backups; regular tests of backup procedures; protection of backups physically and through encryption; and retention of at least one offline backup to mitigate against malware.
11. **Secure Configuration for Network Devices such as Firewalls, Routers, and Switches:** Agencies shall adopt and document standard secure configurations for all network devices deployed within the agency. Agencies shall adopt security configurations of network devices. All configuration changes shall be documented and approved via a formal change control process. Automated tools shall be used to verify configurations, detect changes, and alert security personnel of changes. Devices shall be managed using multi-factor authentication and an encrypted session. The latest stable version of any security update shall be installed on all network devices. A management virtual local area network (VLAN) shall be established to separate network management traffic from business traffic.
12. **Boundary Defense:** DAS OIT shall implement an intrusion detection system (IDS) at the network boundary, and a web filtering solution. Agencies may implement additional boundary defenses, such as, but not limited to data loss prevention (DLP) systems in consultation with DAS OIT.
13. **Data Protection:** Agencies shall adopt practices to protect the **Confidentiality** and **Integrity** of **Confidential Data**, consistent with the CIS controls. DAS OIT shall implement data protection controls on enterprise cloud services, such as SharePoint Online and OneDrive, to protect the Confidentiality and Integrity of Confidential Data. These include, but are not limited to, protecting data in use; data in motion, and data at rest. Refer to Ohio Administrative Policy IT-14, "Data Encryption and Securing Confidential Data," for additional requirements.
14. **Controlled Access Based on the Need to Know:** Agencies shall implement access controls based upon the principles of need to know and least privilege, consistent with the guidance in the CIS controls and the access control (AC) family of controls in NIST SP 800-53 (Revision 4).
15. **Wireless Access Control:** Agencies shall implement controls to protect wireless devices, which are consistent with the guidance in the CIS controls. Agencies shall first utilize the

enterprise wireless as a service (WaaS) offering to implement and protect wireless local area networks (LANs), wireless access points, and wireless client systems.

16. **Account Monitoring and Control:** DAS OIT shall establish enterprise controls to manage the lifecycle for system and application accounts. Agencies shall implement controls to monitor and control agency maintained system and user accounts consistent with the guidance in the CIS controls.
17. **Implement a Security Awareness and Training Program:** Agencies shall comply with the requirements outlined in Ohio Administrative Policy IT-15, “Information Security and Privacy Awareness Training.”
18. **Application Software Security:** Agencies shall implement application security controls consistent with the guidance in the CIS controls.
19. **Incident Response and Management:** Agencies shall report ***Information Security and Privacy Incidents*** to DAS OIT immediately upon discovery, and fully cooperate with the DAS OISP Security Incident Response Team. Refer to Ohio Administrative Policy IT-18, “Information Security & Privacy Incident Response,” for additional details.

DAS OISP shall establish incident response and management capabilities to effectively and efficiently handle security incidents. Agencies shall also develop their own internal incident response procedures. Due to the sensitive nature of incident response and investigation, agencies shall involve their chief legal counsel as well as human resources in these procedures. Additionally, DAS OISP and agency incident response procedures shall be tested annually.

20. **Penetration Tests and Red Team Exercises:** DAS OISP shall provide penetration testing on a periodic basis to ensure effectiveness of implemented controls. Agencies shall perform or sponsor additional penetration testing on a periodic basis to ensure the effectiveness of implemented controls.

Additionally, agencies shall consider having external teams perform exercises to further assess the efficacy of their defenses consistent with the guidance in the CIS Controls.

B. **Procedures**

1. **Exception Process:** To request an exception to one or more of the requirements outlined in this standard, please complete an IT Security Exception Request form.
 - a) The form is located within the IT Enterprise Services Portal under the “Services & Products” category.
 - b) If you have any questions, please contact DAS OISP (refer to Section VII. Inquiries for contact information).

2. **Obtaining CIS Benchmark Resources:** Any user with an e-mail address that ends in “ohio.gov” has the ability to login into the CIS website and create a CIS ID. From there, users can access or download the available CIS benchmarks and participate in related technical communities. Visit <https://workbench.cisecurity.org/login> to create an account.

For questions or for additional information, please contact DAS OISP (refer to Section VII. Inquiries for contact information).

IV. Definitions

- A. Availability. Ensuring timely and reliable access to and use of information.¹
- B. Confidential Data. This classification includes Data that is required to be protected by law or regulation, is intended for confidential use, and may not be copied or removed from an agency's operational control without authorized permission. This classification includes Data that, if compromised, may result in loss of life, serious injury, or other harm to an individual or group, or disruption to critical agency operations.
- C. Confidentiality. Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.²
- D. DAS-Managed Information System. Information systems that reside in facilities or infrastructure managed by DAS OIT personnel. Primary responsibility for managing these systems may be assigned to DAS OIT personnel or other outside entities.
- E. Information Security and Privacy Incident. An occurrence that actually or potentially jeopardizes the Confidentiality, Integrity or **Availability** of state information resources. Privacy incidents are a subset of Security Incidents. Examples of Security Incidents include Ransomware, exfiltration of Data, denial of service, account compromise, loss or theft of a computing or data storage device, improper usage or access, information spillage, and successful social engineering.
- F. Integrity. Guarding against improper information modification or destruction and includes ensuring information non-repudiation and authenticity.³
- G. System Classification. Refers to the process of assessing the potential impact to Confidentiality, Integrity and Availability of the evaluated system. In the NIST SP 800-53 publication they refer to FIPS-199, which are the federal guidelines for assessing and classifying information systems.

¹ “NIST Special Publication 800-53 Revision 5, Security and Privacy Controls for Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, September, 2020
<<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>>.

² *Ibid.*

³ *Ibid.*

V. Authority

ORC 125.18

VI. Resources

Document Name	Location
FIPS Publication 199: Standards for Security Categorization of Federal Information and Information Systems	https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.199.pdf
NIST Special Publication 800-53, "Security and Privacy Controls for Federal Information Systems and Organizations"	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
Center for Internet Security (CIS) Controls	https://www.cisecurity.org/controls/
Ohio Administrative Policy IT-18, "Information Security & Privacy Incident Response,"	https://das.ohio.gov/technology-and-strategy/policies/IT-18

VII. Inquiries

For information regarding this standard, please contact:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 39th Floor
Columbus, Ohio 43215

1-614-644-6860 | state.isp@das.ohio.gov

State of Ohio information security and privacy standards may be found online at:
<https://ohid.ohio.gov/wps/myportal/gov/myohio/my-resources/oisp/oisp-services/information-security-privacy-standards>

VIII. Revision History

This standard shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
04/18/2011	Version 1.0, Original Standard
08/27/2018	Version 2.0, updated references from CAG to the CIS Controls. In addition, revised the requirements to address the implementation of enterprise IT security services and to reflect current State of Ohio IT security practices.
11/29/2018	Updated the exception request language to align with the current procedure.
01/15/2020	Updated standard template.
02/10/2022	Updated to clarify the applicable NIST SP 800-53 version. Modified the policy template to reflect the change in agency director.
04/29/2025	Replaced the term sensitive data, or sensitive information, with confidential data. Revised reference to Ohio Administrative Policy IT-14 to reflect the title change. Added a reference to Ohio Administrative Policy IT-18. Updated the template.